

POL-IT-001 - Data Access and Seller Scope Policy

Policy | IT

Document ID	POL-IT-001	Seller ID	Organization-wide
Department	IT	Classification	RESTRICTED
Owner	Admin	Created Date	2026-09-14
Version	4.1	Effective Date	2026-09-14
Related Scenario ID	SC-002, SC-008	Document Type	Policy

RESTRICTED. This policy defines the access control model, including seller scope assignment, clearance determination and the enforcement points that implement them. It is readable only at RESTRICTED clearance.

1. Purpose

This policy defines who may access which enterprise information, on what basis, and how that access is granted, reviewed and revoked.

The platform holds seller-specific commercial, technical and financial information. Access to it is governed by two independent dimensions: **seller scope**, which determines which accounts an identity may see, and **clearance**, which determines the sensitivity level an identity may read. Both must be satisfied for access to be granted.

2. Scope

Applies to all employees, contractors and service accounts accessing any platform system holding seller, customer or operational data.

Applies to documents, tickets, incident records, transcripts, runbooks, policies, database records and analytical extracts.

3. Definitions

Term	Definition
Identity	A named user account or a service account
Seller scope	The set of seller accounts an identity may access
Clearance	The highest classification an identity may read
Organization-wide	Not tied to a single seller; governed by clearance alone
Classification	One of PUBLIC, INTERNAL, CONFIDENTIAL, RESTRICTED
Access decision	The combination of scope and clearance applied to a request
Effective access	The intersection of scope, clearance and any explicit denial
Service account	A non-human identity used by a system component

4. Access Principles

P-1. **Least privilege.** Access is granted for a defined work purpose and reviewed quarterly. It is not granted for convenience or seniority.

P-2. **Two-dimensional.** Scope and clearance are independent. No clearance level grants cross-portfolio access, and no scope grants access above the holder's clearance.

P-3. **Work allocation, not hierarchy.** Scope derives from the accounts an identity actually works on.

P-4. **Deny by default.** Absence of an explicit grant is a denial.

P-5. **No implicit elevation.** An identity acting on a shared component does not thereby gain scope. Engineering work on a platform-wide defect across all sellers grants visibility into the defect record, not into each affected seller's account documents.

P-5 is a deliberate restriction and a common source of confusion. An engineer remediating a platform defect affecting twelve accounts can see the defect record and the technical detail, but not the commercial account documents for accounts outside their scope. Where account-specific detail is required for remediation, it is provided through a scoped extract rather than by widening scope.

5. Classification Model

5.1 Levels

Level	Rank	Meaning	Typical content
PUBLIC	0	Shareable externally without review	Published marketplace terms
INTERNAL	1	Any employee, regardless of scope	Runbooks, general policies
CONFIDENTIAL	2	Within seller scope only	Account documents, tickets, incident reports, transcripts
RESTRICTED	3	RESTRICTED clearance only	Security records, access model detail, risk determinations

5.2 Classification Rules

R-1. General operational instruction describing how the company works is INTERNAL. It contains no seller-identifying commercial data and any employee may need it.

R-2. Any record naming a specific seller together with commercial, financial or defect detail is at least CONFIDENTIAL.

R-3. Material that would assist an attacker, or that records a security event, credential handling detail or an account risk determination, is RESTRICTED.

R-4. Classification is set by the record author at creation and must be consistent with these rules. Classification must not be assigned to obscure an inconvenient record, nor lowered to broaden access.

R-5. Where a record contains material at two levels, the higher level applies to the whole record. A support ticket containing one credential detail is RESTRICTED in its entirety.

R-6. A RESTRICTED record's existence may be acknowledged in a CONFIDENTIAL record, but its contents must not be reproduced there.

6. Seller Scope Model

6.1 Assignment

R-7. Scope is assigned by the Platform Administrator on the request of the department head, based on documented work allocation.

R-8. Scope is recorded as an explicit list of seller identifiers. Organization-wide scope is reserved for the Platform Administrator and is recorded as such.

R-9. Scope is reviewed quarterly. Continued access requires continued justification; access is not retained because it was previously granted.

R-10. Scope is revoked within one working day of a change of role, and immediately on termination.

6.2 Reference Assignments

The following assignments are current and are provided as the reference model.

Identity	Department	Seller scope	Clearance
Aditya Verma	Business	S001, S003	CONFIDENTIAL
Rahul Sharma	Support	S001, S002	CONFIDENTIAL
Vikram Singh	Engineering	S001, S002	CONFIDENTIAL
Neha Gupta	Operations	S002, S004	RESTRICTED
Admin	IT	Organization-wide	RESTRICTED

R-11. Scope overlap is expected and desirable. S001 appears in three scopes because three departments legitimately hold different records about the same account.

R-12. Clearance and scope are independent. Neha Gupta holds RESTRICTED clearance but sees only S002 and S004. Admin holds organization-wide scope but that scope does not extend to records above RESTRICTED, because no such level exists.

7. Access Decision

R-13. An access request is granted only where **all** of the following hold:

1. The record's classification is at or below the identity's clearance.
2. Either the record is organization-wide, or the record's seller identifier

is within the identity's scope.

3. No explicit denial applies.

R-14. The decision is evaluated per record, not per query or session. Aggregation must not produce disclosure that per-record evaluation would prevent.

R-14 is the rule that makes scope meaningful. An identity with scope over S001 and S002 must not be able to infer S003's commercial position by aggregating query results, even where every individual record returned is within scope. Aggregate results that disclose out-of-scope accounts must be suppressed rather than partially returned.

R-15. Where a request spans multiple sellers and the requester's scope covers only some of them, the requester is informed that results are scoped rather than being silently given an incomplete answer.

R-16. Where an identity requires access outside scope for a defined task, a **scoped extract** is created by the data owner containing only the records required, with an expiry. Scope is not widened for the task.

8. Service Accounts

R-17. Service accounts hold the minimum scope and clearance required to perform their function.

R-18. A service account must not hold organization-wide access where a scoped access is sufficient.

R-19. Service account credentials are enrolled in automated rotation with a maximum age of 90 days.

R-20. Service accounts must be documented with an owner, a purpose and a review date.

R-21. Separate credentials must be issued for staging and production. A credential shared across environments is prohibited.

R-22. IP allowlisting is required for all seller file transfer endpoints.

9. Responsibilities

Role	Responsibility
IT (Platform Administrator)	Scope assignment, clearance assignment, reviews, revocation
Department heads	Request and justify access for their staff
Data owners	Correct classification of records they author
All identities	Use access only for its stated purpose; report suspected exposure
Engineering	Enforce the access decision in system implementation

10. Exceptions

E-1. Emergency access outside scope may be granted by the Platform Administrator for incident response, with a mandatory review within 5 working days and automatic expiry.

E-2. A scoped extract may include out-of-scope records where a named data owner authorises it, with an expiry no later than 30 days.

E-3. No exception may waive R-3 (record classification), R-14 (per-record evaluation) or R-21 (separate staging and production credentials).

11. Escalation

Situation	Escalate to	Timeframe
Suspected unauthorised access	IT, as a security incident	Immediately
Scope appears incorrect or stale	Platform Administrator	1 working day
Access required outside scope	Data owner, as a scoped extract request	2 working days
Review identifies unrequired access	Platform Administrator	Revoke within 5 working days
Classification dispute	Policy owner	5 working days

12. Enforcement

Access decisions are enforced at the application boundary. Reporting and analytical interfaces apply the same decision as transactional interfaces; a reporting view is not exempt.

Quarterly access reviews test every identity against its current work allocation. A review finding unrequired access results in revocation, not in a note.

Classification is validated at record creation. A record created without a classification is not stored.

13. Review History

Version	Date	Change	Owner
1.0	2022-09-15	Initial access policy	IT
2.0	2024-03-11	Seller scope model introduced; two-dimensional access	IT
3.0	2025-10-06	Classification model formalised; RESTRICTED level added	Admin
4.0	2026-06-12	Service account controls; separate staging and production credentials	Admin
4.1	2026-09-14	Per-record and aggregation rules clarified (R-14, R-15)	Admin

Next scheduled review: March 2027.